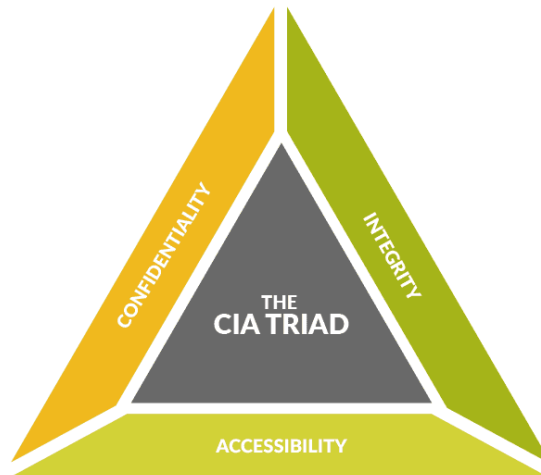


CIA Triad

The CIA Triad is the foundational model for information security. Every security control, every attack, and every incident response decision can be mapped back to one (or more) of these three pillars.



1. Confidentiality

Definition: Ensuring information is accessible only to those authorized to see it.

What breaks it: Data breaches, eavesdropping, shoulder surfing, improper access controls, unencrypted data in transit/at rest.

Controls that enforce it:

- **Encryption** — AES-256 for data at rest, TLS 1.3 for data in transit
- **Access control models** — RBAC (Role-Based), MAC (Mandatory), DAC (Discretionary)
- **Authentication** — MFA, strong password policies
- **Data classification** — Public / Internal / Confidential / Restricted labeling
- **Least privilege** — users/processes get only the access they need

Attacks targeting confidentiality:

- Man-in-the-Middle (MITM) attacks

- SQL injection (data exfiltration)
- Packet sniffing (Wireshark on unencrypted traffic)
- Credential stuffing / password spraying
- Social engineering / phishing

Real-world example: If an attacker exploits an IDOR (Insecure Direct Object Reference) vulnerability to view another user's account data by changing `user_id=101` to `?user_id=102`, that's a direct confidentiality violation — something you'd flag in a VAPT report.

2. Integrity

Definition: Ensuring data is accurate, consistent, and hasn't been tampered with — whether in storage, transit, or during processing.

What breaks it: Unauthorized modification, man-in-the-middle tampering, malware altering files, SQL injection that modifies records, insider threats.

Controls that enforce it:

- **Hashing** — SHA-256, SHA-3 (verifying file integrity, checksums)
- **Digital signatures** — verifying authenticity and non-repudiation
- **Version control / audit logs**
- **File Integrity Monitoring (FIM)** tools — Tripwire, OSSEC
- **HMAC** — for message integrity in transit
- **Database constraints & input validation** — prevents malicious data manipulation

Attacks targeting integrity:

- SQL injection (UPDATE/DELETE statements)
- MITM with packet tampering
- Malware that modifies system files
- Session hijacking leading to unauthorized transactions
- Defacement attacks

Real-world example: If you're doing a pentest and find that an e-commerce app doesn't validate the `price` parameter server-side (only client-side), an

attacker could tamper with the request and change a ₹5000 item's price to ₹5 — a textbook integrity violation.

3. Availability

Definition: Ensuring systems, applications, and data are accessible to authorized users when needed.

What breaks it: DoS/DDoS attacks, ransomware, hardware failure, natural disasters, misconfigurations, resource exhaustion.

Controls that enforce it:

- **Redundancy** — RAID, failover clusters, load balancers
- **Backups** — 3-2-1 backup strategy
- **DDoS protection** — Cloudflare, AWS Shield, rate limiting
- **Disaster Recovery (DR) / Business Continuity Planning (BCP)**
- **Patch management** — prevents exploits that crash services
- **High availability (HA) architecture**

Attacks targeting availability:

- DDoS (volumetric, protocol, application-layer)
- Ransomware (encrypts data, denies access)
- Resource exhaustion (e.g., ReDoS, Slowloris)
- Physical attacks on infrastructure

Real-world example: As a SOC L1 analyst, if you see a sudden spike in traffic to a single endpoint from thousands of distinct IPs, correlated with high CPU alerts — that's a likely DDoS event threatening availability, and you'd escalate per your incident response playbook.

How CIA Maps to Your Work

Concept	Confidentiality	Integrity	Availability
OWASP Top 10	A01 (Broken Access Control), A02 (Crypto Failures)	A03 (Injection), A08 (Software/Data Integrity Failures)	A05 (Security Misconfig can cause DoS)

Concept	Confidentiality	Integrity	Availability
CVSS v3.1 metrics	C metric	I metric	A metric — this is <i>literally</i> built into CVSS scoring
SOC monitoring	Data exfiltration alerts	FIM alerts, unauthorized change detection	Uptime/latency monitoring, DDoS alerts
Pentest reporting	IDOR, sensitive data exposure	Parameter tampering, injection	DoS PoCs (usually noted, rarely exploited live)